

AI Vendor Red Flag List

Use this list before approving an AI vendor, SaaS AI feature, embedded AI capability, or new AI-enabled workflow. A red flag does not always mean automatic rejection, but it should pause approval until the issue is understood and documented.

Immediate pause flags

Pause the review if any of these are true:

- Vendor cannot say whether customer inputs or outputs are used for model training or product improvement.
- Vendor trains on customer data by default and offers no opt-out.
- Tool would process sensitive, regulated, confidential, customer, employee, student, health, financial, legal, biometric, child, or NDA data without appropriate review.
- Tool may make or meaningfully inform decisions about people without qualified legal, privacy, HR, security, or leadership review.
- Vendor has no privacy policy, terms, security documentation, or data retention answer.
- Vendor cannot identify subprocessors or underlying model providers where relevant.
- Vendor refuses to sign a needed DPA, BAA, transfer agreement, confidentiality addendum, or sector-specific agreement.
- Vendor has an unresolved security incident or refuses to answer basic security questions.
- Contract terms allow broad data use that conflicts with your obligations or expectations.
- The internal team cannot describe the use case clearly.

Data red flags

- Data categories are unclear.
- Users plan to paste or upload whatever is convenient.
- Sensitive data rules are not written down.
- Vendor stores prompts, files, recordings, or outputs longer than needed.
- Vendor cannot delete data on request or at termination.
- Vendor can share data with affiliates, partners, or subprocessors without clear limits.
- Data leaves expected jurisdictions without documented transfer terms.
- The tool logs more data than the team expects.

Use-case red flags

- AI output would be sent to customers or the public without human review.
- AI output would be relied on for hiring, firing, pricing, credit, insurance, housing, education, health, benefits, legal, safety, public services, or eligibility decisions.
- The tool will be connected to email, CRM, databases, file storage, code repositories, production systems, or internal chat without IT/security review.
- The tool replaces an existing control, reviewer, approval, or quality check.
- The business owner wants approval before the review is complete.
- The use case keeps expanding during the review.

Vendor posture red flags

- No SOC 2, ISO 27001, penetration test summary, or reasonable equivalent for non-public data use.
- No MFA, SSO, role-based access, or admin controls for multi-user business use.
- No audit log for important workflows.
- No change notice for model, feature, retention, or subprocessor changes.
- No documented incident response or breach notification process.
- No clear uptime, support, or continuity commitment for business-critical use.
- Vendor markets the tool as accurate, compliant, unbiased, or risk-free without evidence.

AI-specific red flags

- Vendor cannot explain hallucination limits or known failure modes.
- Vendor cannot explain prompt injection, jailbreak, abuse, or safety controls.
- Vendor provides no relevant evaluation, testing, red-team, or bias information.
- Guardrails cannot be configured for your use case.
- Humans cannot review output before it is sent or used.
- Model changes can materially change behavior without notice.
- Vendor claims the AI can replace professional judgment in legal, medical, financial, employment, or safety contexts.

Contract red flags

- Vendor owns or can reuse your inputs in ways you do not accept.
- Output ownership is unclear.
- Liability caps are too low for the use case.
- IP indemnity is missing for public-facing creative or content use where it matters.
- Renewal, cancellation, or data export terms are unclear.
- Vendor can change material terms without reasonable notice.
- You cannot preserve records needed for audit, customer inquiry, regulator inquiry, or dispute response.

Possible responses

- Request more information.
- Narrow the approved scope.
- Limit use to public data.
- Require human review.
- Require a signed DPA, BAA, transfer agreement, or confidentiality terms.
- Require SSO, MFA, role controls, logging, or admin settings.
- Require training/product-improvement opt-out.
- Run a pilot with non-sensitive data only.
- Send to legal, privacy, security, HR, procurement, or leadership review.
- Reject for the proposed use case.

Reviewer notes

Red flag identified:

Why it matters:

Response or condition:

Owner and due date:

Disclaimer

This document is a template for educational and informational purposes only. It is not legal advice and does not create an attorney-client relationship. Consult qualified counsel and appropriate privacy, security, procurement, HR, and technical reviewers before relying on this list for legal compliance, regulated use cases, sensitive data use, or vendor approval decisions.